

FRAUD READINESS ADVISORY

Essential Fraud Readiness Review

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Vhutshilo Foods Manufacturing (Pty) Ltd

Report reference RPT-MKFRS-V12-ESS-VHUTSHILO-V1
Generated 24 August 2026
Essential package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	3
What the result means	4
Domain overview	6
Priority findings, contradictions and scenarios	8
Priority risks	14
Leadership decisions and roadmap	17
Proof requirements	21
Methodology, limitations and next steps	22
Appendix: supporting material	22
Complete supporting detail	22
E1. Supporting control actions	23
E2. Definitions and score basis	25

Executive summary

Fraud controls are not yet consistently embedded.

Reported readiness

43

out of 100

Developing

Overall readiness position

The assessment places the organisation at 43.33/100 with a Developing maturity. This position recognises that useful capability already exists — notably a relatively stronger Whistleblowing and Reporting Culture (D6) — while several control and detection domains remain materially weaker and concentrate the exposure. The stronger reporting culture provides a practical foundation for improving intake and containment, but the lower-scoring domains in identity and digital risk (D8), fraud risk identification (D2), operational controls (D3), detection (D4) and continuous improvement (D10) limit the organisation's ability to convert reports into timely containment, investigation and corrective control design.

This assessment is strategic advisory analysis based on management responses and the MK scoring method; it is without verification of operating effectiveness by this review.

What is shaping the readiness position

Five connected themes explain why the maturity reading clusters where it does. First, identity and access governance is incomplete: privileged and ordinary access controls are not yet consistently restricted, logged and recertified, creating a route to alter value-bearing records (the relevant control). Second, fraud governance and risk discipline are informal at the process level, so process-specific fraud scenarios and clear treatment ownership are not fully mapped or refreshed (the relevant control). Third, supplier and payment integrity controls are partly designed and not yet enforced before supplier activation or payment, leaving a payment-diversion pathway if beneficiary details are changed without independent verification (the relevant control). Fourth, incident response and evidence integrity are at an initial stage, so preserving, custodising and escalating evidence is not yet repeatable across distributed locations (the relevant control). Fifth, monitoring and exception-handling coverage is still partial, with analytics and rule-based detection only partly designed and not yet tuned into a cycle that forces timely escalation (the relevant control). Together these themes create a coherent explanation for the assessed weaknesses and show where remediation should concentrate.

What this means for management

The score and diagnostic pattern mean management should treat the result as a targeted starting point: build on the relative strength in reporting culture to stabilise intake and evidence custody immediately, and then sequence controls to close the higher-priority gaps that enable supplier diversion, privileged-access misuse and unreviewed exceptions. The score is the management signal to move from informal, reactive practice to documented, owned and evidence-backed controls in the domains that drive material exposure.

COVERAGE

100%

CRITICAL GAPS

6

MAJOR GAPS

3

Assessment scope and limitations

APPLICABLE CONTROLS	CONTROL VISIBILITY	EXCLUDED AREAS	UNCERTAINTY RESPONSES
60	100%	8	0

This is a provisional result. Differences in assessed scope or uncertainty may limit comparison with other assessments.

4 control areas were completed using the assessment's oversight question set rather than the standard question set. They remain in the scored scope. Excluded areas are outside the assessed scope and are not treated as weaknesses.

The aggregate result and its ten underlying domains

The Developing result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.

Fraud Leadership and Governance 42 Developing	Fraud Risk Identification 39 Reactive	Operational Fraud Controls 41 Developing	Fraud Detection Capability 41 Developing	Fraud Incident Response 44 Developing
Whistleblowing and Reporting Culture 61 Structured	Third-Party and Supply Chain Fraud Risk 47 Developing	Digital and Identity Fraud Risk 38 Reactive	Fraud Culture and Awareness 57 Developing	Continuous Improvement and Fraud Risk Monitoring 41 Developing

What the result means

The recorded conditions requiring first attention

CRITICAL CONTROL GAP · FRAUD RISK IDENTIFICATION Fraud risks are mapped to the organisation's important processes. This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.
CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf. This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.
CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS System and data access is granted against current role requirements. This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD INCIDENT RESPONSE

Evidence linked to suspected fraud is identified, preserved and handled appropriately.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

Access to sensitive systems, administrator rights and confidential data is restricted.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

Where a strong average can still hide a real gap

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · OPERATIONAL FRAUD CONTROLS

Supplier onboarding verifies business identity, ownership and initial banking information before approval.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Core domain Fraud Risk Identification scored below 40.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Core domain Fraud Leadership and Governance scored below 60.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Management response: see the leadership roadmap section for accountable executive mandates, escalation authority and the fraud-risk implementation and control-effectiveness review cadence.

A domain score is an average. It can still contain one specific control that is materially weaker than the others feeding into the same number. The purpose of this report is to surface that unevenness so leadership does not treat the overall score as a substitute for control-level attention.

DOMAIN OVERVIEW

Domain overview

The systemic pattern

The underlying condition that links the priority findings is an absence of process-level ownership, consistent control evidence and repeatable monitoring. Fraud risks are not yet mapped and signed by process owners in a way that ties scenarios to the preventive and detective controls that must operate day-to-day (the relevant control). Where supplier onboarding and bank verification are partly designed (the relevant control), and role-based and privileged access governance remain informal or inconsistent (the relevant control, the relevant control), the organisation lacks the authoritative facts and decisive challenge needed to stop value being redirected at supplier- and payment-change points. At the same time, analytics and rule-based detection remain partly designed (the relevant control), so exceptions do not reliably surface for accountable review, and evidence preservation and chain-of-custody handling are informal (the relevant control), weakening containment when concerns are raised. The relative strength in whistleblowing and reporting (D6) matters only if intake is routed into a reliable containment and investigative path; presently reporting capacity is not consistently converted into preserved evidence, mapped scenarios or tuned monitoring that forces remediation. In short, the causal chain runs from incomplete fraud-risk mapping through inconsistent supplier and access controls to limited detection and fragile incident containment — and that chain is the priority management question to close.

Foundations: ownership, awareness and reporting culture

Executive ownership, risk identification, workforce awareness and safe reporting.

Fraud Leadership and Governance

42/100

Developing reported position.

Fraud Risk Identification

39/100

Reactive reported position.

Critical condition: Fraud risks are mapped to the organisation's important processes.

Fraud Culture and Awareness

57/100

Developing reported position.

Whistleblowing and Reporting Culture

61/100

Structured reported position.

Operational defence: controls, detection and third parties

Day-to-day prevention, detection and supplier-facing control operation.

Operational Fraud Controls

41/100

Developing reported position.

Priority condition: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

Critical condition: System and data access is granted against current role requirements.

Fraud Detection Capability

41/100

Developing reported position.

Priority condition: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

Third-Party and Supply Chain Fraud Risk

47/100

Developing reported position.

Response and evolution: incidents, digital risk and improvement

Incident response, digital and identity defence, and continuous control improvement.

Fraud Incident Response

44/100

Developing reported position.

Priority condition: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

Digital and Identity Fraud Risk

38/100

Reactive reported position.

Priority condition: Access to sensitive systems, administrator rights and confidential data is restricted.

Developing reported position.

PRIORITY FINDINGS, CONTRADICTIONS AND SCENARIOS

Priority findings, contradictions and scenarios

Role distinction: Control owner identifies the role responsible for implementing or operating the control. Accountable executive identifies the executive role responsible for sponsorship, decision rights and escalation. The two roles may legitimately differ.

Value diversion through supplier and payment processes

Supplier-onboarding verification is partly designed and important elements are incomplete or inconsistent (the relevant control). Without complete, pre-activation verification of legal identity, ownership and bank details and a second reviewer's approval, supplier activation and payment processes remain exposed to diversion or fictitious relationships. Management implication: enforce an independent pre-activation verification and second-review requirement so no vendor or bank detail is activated in the ERP without a retained evidence package and independent sign-off.

Weak challenge at identity, transaction and sensitive-change points

Analytics and rule-based detection are partly designed (the relevant control), and role- and privileged-access governance is either partly designed or informal (the relevant control, the relevant control). When monitoring tests, exception ownership and access recertification are not consistently in place, unusual transactions, beneficiary changes and sensitive system changes may not receive timely challenge. Management implication: implement a defined monitoring catalogue, a named reviewer for exceptions and a strict recertification rhythm for sensitive access so that unusual activity is escalated and constrained before value is redirected.

Limited containment and learning after suspected fraud

Evidence preservation and chain-of-custody handling were self-assessed as informal or reactive (the relevant control). If suspected matters are not opened into an evidence register, hashed or sealed and placed in an access-controlled repository with a recorded custody trail, investigations can be delayed or undermined and learning loops remain closed. Management implication: define and operate an intake, preservation and custody route for every material case so that reporting becomes an input to containment and improvement rather than an unresolved alert.

Additional material control pattern

Several control gaps that are material but distinct from the three exposures above were identified: privileged access governance needs a complete sensitive-access inventory and quarterly recertification (the relevant control); role-based access must be aligned to current role requirements and segregation-of-duties exceptions managed (the relevant control); conflicts of interest involving suppliers are managed informally and should be formalised (the relevant control); and the workforce's ability to use reporting channels is partly designed and needs clearer guidance and testing (the relevant control). Management implication: treat privileged and ordinary access governance and third-party conflict declarations as discrete workstreams with named owners and completion criteria so these controls cease to be informal dependencies.

MATERIAL FINDING 1

MATURITY CONSTRAINT

Fraud Risk Identification: Fraud risks are mapped to the organisation's important processes.

DOMAIN

Fraud Risk Identification

ASSESSED CONTROL STATE

Fraud risks are mapped to the organisation's important processes.
— Informal / reactive

DIAGNOSIS

Process-level fraud risk mapping was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Risk / compliance accountable owner with named process owners

IMPLEMENTATION

Moderate difficulty · 90 days

MATERIAL FINDING 2

MATURITY CONSTRAINT

Operational Fraud Controls: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

DOMAIN

Operational Fraud Controls

ASSESSED CONTROL STATE

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf. — Partly designed

DIAGNOSIS

Supplier-onboarding verification was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Procurement / Vendor Master

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 3

PRIORITY CONTROL WEAKNESS

Digital and Identity Fraud Risk: Access to sensitive systems, administrator rights and confidential data is restricted.

DOMAIN

Digital and Identity Fraud Risk

DIAGNOSIS

Privileged and administrator access governance was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Access to sensitive systems, administrator rights and confidential data is restricted. — Informal / reactive

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Identity and Access Management

IMPLEMENTATION

High difficulty · 60 days

MATERIAL FINDING 4

PRIORITY CONTROL WEAKNESS

Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

DOMAIN

Fraud Incident Response

DIAGNOSIS

Fraud evidence preservation and chain of custody was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Evidence linked to suspected fraud is identified, preserved and handled appropriately. — Informal / reactive

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Investigation lead / Evidence custodian

IMPLEMENTATION

High difficulty · 60 days

Operational Fraud Controls: System and data access is granted against current role requirements.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Role-based user-access governance was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

System and data access is granted against current role requirements. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Business system owners

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 6

PRIORITY CONTROL WEAKNESS

Fraud Detection Capability: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

DOMAIN

Fraud Detection Capability

DIAGNOSIS

Analytics and rule-based detection was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Fraud analytics owner

IMPLEMENTATION

High difficulty · 90 days

MATERIAL FINDING 7

CROSS-DOMAIN DEPENDENCY

Third-Party and Supply Chain Fraud Risk: Employees are required to disclose and manage conflicts of interest involving suppliers or third parties.

DOMAIN

Third-Party and Supply Chain Fraud Risk

DIAGNOSIS

Conflict of interest declaration and management was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.

ASSESSED CONTROL STATE

Employees are required to disclose and manage conflicts of interest involving suppliers or third parties. — Informal / reactive

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

CONTROL OWNER

Compliance with Human Resources

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Legal / investigations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 8

CROSS-DOMAIN DEPENDENCY

Whistleblowing and Reporting Culture: Employees know how to recognise suspected fraud and use the reporting channel.

DOMAIN

Whistleblowing and Reporting Culture

DIAGNOSIS

Workforce ability to use the reporting channel was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.

ACCOUNTABLE EXECUTIVE

People / workforce accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Employees know how to recognise suspected fraud and use the reporting channel. — Partly designed

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

CONTROL OWNER

Ethics / Compliance lead

IMPLEMENTATION

Low difficulty · 60 days

Contradictions

CONTRADICTION 1

Operational and privileged-access weaknesses indicate one systemic access-governance issue

WHAT THE ASSESSMENT SHOWS

Digital and Identity Fraud Risk — Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls — Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

WHY IT MATTERS

Excess access across ordinary and privileged environments can create an end-to-end manipulation and concealment route.

LEADERSHIP VERIFICATION

Is one complete identity, role and recertification population used across ordinary and privileged access reviews?

Scenarios and assurance tests

Conditional exposure pathways

The scenarios below are conditional illustrations of how the linked weaknesses could combine if not treated; they are management tests of prevention, detection and containment.

SUPPLIER OR PAYMENT INSTRUCTION IS DIVERTED THROUGH A COMPROMISED OR FICTITIOUS RELATIONSHIP

This pathway can begin when supplier onboarding and bank-detail changes are processed without consistent independent verification (SCENARIO-001). The current environment could fail if an outsourced supplier-management step accepts a change shortly before payment and there is no pre-activation evidence pack or second reviewer blocking ERP activation. Warning indicators include a supplier activated before verification, a bank-detail change shortly before payment, or an unresolved ownership/conflict match. Immediate containment is to pause the affected supplier or payment instruction, independently confirm the trusted beneficiary details and preserve the approval trail. Longer-term response is to implement independent supplier and bank-detail verification, dual approval and continuous vendor-population monitoring so activation and payment cannot proceed without the evidence package.

PRIVILEGED ACCESS IS USED TO ALTER A VALUE-BEARING RECORD, ENTITLEMENT OR AUDIT TRAIL

This pathway can begin where privileged or administrator accounts remain usable across locations without consistent recertification (SCENARIO-002). The environment could fail if sensitive access is not fully inventoried, strongly authenticated, session-logged and recertified quarterly. Warning indicators include missed recertifications, unknown privileged accounts, leaver access remaining beyond the defined window, or unusual entitlement changes. Immediate containment is to suspend or restrict the affected entitlement, preserve access and audit logs, and route the change for accountable review. Longer-term response is implementing least-privilege role-based access, privileged-session logging, quarterly independent recertification and event-driven removal processes.

RECORDS OR REPORTING ARE WEAKENED AFTER A SUSPECTED FRAUD MATTER, ALLOWING EXPOSURE TO REPEAT

This pathway can begin when a suspected matter originates at a site and records remain uncontrolled at the local level because evidence preservation and custody are informal (SCENARIO-003). The environment could fail if no evidence register is opened, integrity checks are absent and custody transfers are unrecorded, making scope and timing harder to establish when the matter is escalated. Warning indicators include unexplained custody gaps, unavailable records or overdue severity decisions. Immediate containment is to open an incident record, preserve relevant records under controlled custody and assign a named containment and investigation owner. Longer-term response is to implement protected reporting, severity-based escalation, formal evidence preservation and repeat-exposure review so suspected matters are contained and converted into action.

PRIORITY RISKS

Priority risks

RISK 1 · FRAUD RISK IDENTIFICATION

CRITICAL

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as manipulation of a value-bearing adjustment is never mapped to a control owner.

Because the self-assessment records "Fraud risks are mapped to the organisation's important processes" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as manipulation of a value-bearing adjustment is never mapped to a control owner. Consequence pathway: Material process exposures can remain without explicit control ownership or treatment; Unmapped process-level fraud routes can leave value diversion or loss outside targeted controls.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Risk Identification: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

90 days

RISK 2 · FRAUD DETECTION CAPABILITY

CRITICAL

Manual review cannot cover transaction volume, so without data-driven tests the majority of activity is never examined and structured schemes persist undetected.

Because the self-assessment records "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that manual review cannot cover transaction volume, so without data-driven tests the majority of activity is never examined and structured schemes persist undetected. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Detection Capability: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

TARGET PERIOD

90 days

RISK 3 · FRAUD INCIDENT RESPONSE

CRITICAL

Fraud evidence loses integrity or chain of custody

Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Incident Response: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

TARGET PERIOD

60 days

RISK 4 · OPERATIONAL FRAUD CONTROLS

CRITICAL

Fictitious or conflicted supplier enters the vendor population

Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

60 days

RISK 5 · OPERATIONAL FRAUD CONTROLS, DIGITAL AND IDENTITY FRAUD RISK

CRITICAL

Unauthorised system access enables transaction or record manipulation

Because privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified, there is a risk that a privileged user or compromised administrator identity alters records, controls or logs without timely detection. Consequence pathway: confidence in digital controls is damaged; critical systems and audit trails lose integrity; high-impact transactions or data can be manipulated; security and personal-data obligations may be breached.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Digital and Identity Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REQUIRED TREATMENT

IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control. System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

TARGET PERIOD

60 days

RISK 6 · WHISTLEBLOWING AND REPORTING CULTURE

MEDIUM

A channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud.

Because the self-assessment records "Employees know how to recognise suspected fraud and use the reporting channel" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that a channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud. Consequence pathway: Early-warning information may never reach an independent reviewer; suppressed reporting lets fraud continue longer.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Moderate — Moderate impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Whistleblowing and Reporting Culture: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.

ACCOUNTABLE EXECUTIVE

People / workforce accountable owner

TARGET PERIOD

60 days

LEADERSHIP DECISIONS AND ROADMAP

Leadership decisions and roadmap

Target control environment

Strengthen fraud-risk identification and treatment

Management should close the informal mapping gap by producing a process-by-process fraud map covering every material value-bearing process (the relevant control). Each map must record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon and any residual gaps. The Risk / compliance accountable owner, with named process owners, must retain the process inventory and process-owner sign-off; the completion test is 100% of material value-bearing processes having a signed fraud map with named controls and residual gaps. Decisions to approve accountable executive mandates, remediation versus acceptance and the control-design standard (the relevant control, the relevant control, the relevant control) should be taken promptly to give this work clear authority and sequencing.

Strengthen supplier onboarding and identity checks

Procurement and the vendor-master process must implement the approved pre-activation checklist so every supplier is verified for legal identity, beneficial ownership, banking and conflicts before activation (the relevant control). The vendor master must retain the evidence package and block ERP activation until a second reviewer signs; the effectiveness measure is 100% of newly activated suppliers having a complete pre-activation evidence pack and independent approval. This control addresses the supplier-payment diversion scenario and should be sequenced as an immediate stabilisation priority.

Strengthen privileged access and recertification

Technology and Identity and Access Management must establish a complete privileged-account register, require named identities and business justification, enforce least privilege and continuous logging, and recertify privileged accounts quarterly (the relevant control). The independent decision to fund specialist capacity where needed (the relevant control) supports any required technical or logging improvements. Completion is measured by quarterly recertification, removal of leaver access within the required window and elimination of unjustified shared admin accounts.

Strengthen monitoring, exception review and escalation

The monitoring owner must build and operate a rule catalogue that maps each data check to a fraud scenario, runs against reconciled data and is tuned monthly from confirmed outcomes (the relevant control). This includes duplicate and near-duplicate payments, supplier and employee bank-detail matches, unusual approval pairings and dormant-account reactivation checks. The monitoring owner must assign alerts to trained reviewers, retain investigation evidence and escalate high-risk alerts immediately; governance decisions on sequencing and reporting cadence (the relevant control, the relevant control) should ensure prerequisites are completed and progress is visible to oversight. The completion test is that all priority fraud scenarios have at least one operating data check with monthly tuning completed.

Strengthen evidence preservation and custody

Legal, investigations and the investigation lead must implement a formal evidence register, chain-of-custody forms, hashed or sealed originals and access-controlled repositories (the relevant control). Trained custodians must record every transfer, preserve hashes or seals and escalate any custody break immediately. The completion test is that sampled material-case evidence has a complete custody trail and matching integrity check, and intake is stabilised so reporting reliably results in preserved evidence.

Strengthen role-based access and segregation

Business system owners must reconcile role-to-access matrices with current responsibilities, enforce least-privilege provisioning, separate incompatible initiation and approval rights and retain request and approval trails (the relevant control). Quarterly review and reconciliation to joiner/mover/leaver events must be formalised so the independent completion check (100% population reviewed quarterly and timely exception closure) proves the control is operating. the relevant control and the relevant control guide the sequencing and design standard applied to these changes.

Leadership decisions required

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	Finance / operations accountable owner	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	Finance / operations accountable owner	60 days	Known risk pathways remain untreated without a documented acceptance basis.
3	Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	Finance / operations accountable owner	30 days	Partial or inconsistent designs fail to address the causal pathway.

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Technology / security accountable owner	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Use authoritative roadmap dependency IDs and escalate threatened prerequisites.	Finance / operations accountable owner	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	Finance / operations accountable owner	60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

30/60/90-day roadmap

The first 30 days establish decisions and ownership; the 60- and 90-day windows implement and evidence the linked controls.

By 30 days — Stabilise

In the first 30 days focus on stabilising accountability for the priority gaps and putting proportionate incident and evidence-preservation basics in place. Execute the the relevant roadmap action stabilisation item: implement independent legal-identity, ownership, banking and conflict checks before supplier activation and evidence retention for any supplier activation. Concurrently, clarify the incident intake route and who will protect evidence on first report so that any new concern is paused, recorded and preserved pending triage. Proof of completion is the retained onboarding evidence package and a documented intake process for suspected matters.

First 30 days — decisions and foundations

PRIORITY DECISION	DELIVERABLE	ACCOUNTABLE EXECUTIVE	COMPLETION TEST
Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	Finance / operations accountable owner	Decision recorded, accountable owner confirmed and escalation route documented.
Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	Finance / operations accountable owner	Decision recorded, accountable owner confirmed and escalation route documented.
Approve prerequisite-first sequencing for dependent improvements.	Use authoritative roadmap dependency IDs and escalate threatened prerequisites.	Finance / operations accountable owner	Decision recorded, accountable owner confirmed and escalation route documented.

First 30 days — implementation foundations

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any supplier activated before verification or any ownership/conflict match unresolved.	Finance / operations accountable owner	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.

By 60 days — Establish

Between days 31 and 60 establish the priority preventive and access controls. Implement the the relevant roadmap action, the relevant roadmap action and the relevant roadmap action items: establish evidence preservation and custody procedures with chain-of-custody and an evidence register; reconcile role-based access and segregation-of-duties exceptions against current responsibilities; and reconcile the privileged-account population, enforce named access and retain recertification evidence. These actions require named accountable executives and process owners, and may depend on resourcing decisions recorded under the funding decision (the relevant control). Completion is shown by the proof artefacts each control requires: chain-of-custody forms and evidence register, access request and approval trails with a role-to-access matrix, and privileged-account registers with recertification records.

60-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Incident Response	Implement the target control design for Fraud Incident Response. Escalation trigger: Any unexplained custody gap, integrity mismatch or unauthorised repository access.	Legal / investigations accountable owner / Finance / operations accountable owner	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any missed quarterly review, unassigned account or removal overdue beyond 10 business days.	Finance / operations accountable owner	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
Digital and Identity Fraud Risk	Implement the target control design for Digital and Identity Fraud Risk. Escalation trigger: Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.	Technology / security accountable owner	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
Third-Party and Supply Chain Fraud Risk	Implement the target control design for Third-Party and Supply Chain Fraud Risk. Escalation trigger: An employee-supplier match not investigated, or a declared conflict with no management action.	Finance / operations accountable owner / Legal / investigations accountable owner	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.
Whistleblowing and Reporting Culture	Implement the target control design for Whistleblowing and Reporting Culture. Escalation trigger: A failed channel test, or a site or language group below the awareness threshold.	People / workforce accountable owner	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.

By 90 days — Operate and review

By day 90 begin operating monitoring, exception review and control learning (the relevant roadmap action and the relevant roadmap action). Deploy the monitoring rule catalogue, run the scheduled checks, tune rules from confirmed outcomes and evidence the monthly tuning. Consolidate progress in a management pack and report to the agreed oversight cadence so implementation status and early effectiveness measures are visible. Success measures include operating detection tests against priority scenarios, completed recertifications, and evidence of preserved custody for any sampled matters.

90-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Risk Identification	Implement the target control design for Fraud Risk Identification. Escalation trigger: Any material process unmapped, or a mapped residual gap with no owner.	Finance / operations accountable owner	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
Fraud Detection Capability	Implement the target control design for Fraud Detection Capability. Escalation trigger: A priority scenario with no operating check, or rules unexecuted for a full cycle.	Finance / operations accountable owner / Technology / security accountable owner	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.

Management conclusion

The assessed position is a practical starting point for management action: a Developing maturity with a clear relative strength in reporting culture (D6) and identifiable material gaps in fraud-risk identification (D2), operational controls (D3), detection (D4), and digital and identity risk (D8). Management should convert the existing reporting capability into a stabilised intake and evidence pathway, prioritise supplier verification and privileged-access recertification, and sequence monitoring and process-level fraud mapping so treatment ownership and proof replace informal or reactive practice. Completing the defined control responses within the stated target windows will be the test that the change is real and sustained.

PROOF REQUIREMENTS

Proof requirements

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Control linkage showing preventive and detective controls	Whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable.	Risk / compliance accountable owner with named process owners	Not yet requested
2	Per-process fraud scenario map	Whether each material process has explicit fraud scenarios, relevant roles or permissions and residual exposure documented.	Risk / compliance accountable owner with named process owners	Not yet requested
3	Process inventory identifying material value-bearing processes	Whether the complete population of material value-bearing processes has been identified before fraud-risk mapping is assessed.	Risk / compliance accountable owner with named process owners	Not yet requested
4	Process-owner sign-off	Whether process owners have reviewed and accepted the mapped fraud scenarios, control ownership and residual gaps.	Risk / compliance accountable owner with named process owners	Not yet requested
5	Beneficial-ownership/conflict screening	Whether the beneficial-ownership/conflict screening provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
6	Completed onboarding checklist	Whether the completed onboarding checklist provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
7	Independent registration and bank verification	Whether the independent registration and bank verification provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
8	Second-reviewer approval	Whether the second-reviewer approval provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
9	Approval and business justification	Whether the approval and business justification provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
10	Privileged-account register	Whether the privileged-account register provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
11	Privileged-session/access logs	Whether the privileged-session/access logs provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
12	Quarterly independent recertification	Whether the quarterly independent recertification provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
13	Removal tickets	Whether the removal tickets provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
14	Chain-of-custody forms	Whether each transfer of material evidence records custody, timing and handover without unexplained gaps.	Investigation lead / Evidence custodian	Not yet requested
15	Evidence register	Whether all material evidence items are uniquely recorded, assigned and traceable through the case.	Investigation lead / Evidence custodian	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue items. Every item begins with the status "Not yet requested"; status changes require a separately scoped review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity ceilings and advisory model use only the recorded assessment inputs and the MK Fraud Readiness methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain the specified operating proof before treating a control as effective or a finding as resolved.

Control design standard. Priority controls are specified by responsibility, population or scope, operating frequency, retained evidence, independent challenge, escalation trigger, service level, effectiveness measure and response to failure.

Assessment basis: submitted self-assessment responses and the MK Fraud Readiness methodology.

APPENDIX

Appendix: supporting material

Complete supporting detail

This report presents the highest-priority matters from a complete assessment inventory of 68 controls (60 applicable and 8 excluded). The full assessment identified 25 material findings, 24 risks, 25 control

improvements, 105 evidence artefacts, 25 recommended actions and 59 functional-agenda items.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Operational Fraud Controls	Close the material control weakness recorded for "Transactions or operational activities above defined risk or value thresholds require independent review or approval".	The Finance / operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance / operations accountable owner / 60 days
2	Operational Fraud Controls	Close the material control weakness recorded for "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls".	Human Resources and the Risk / compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Finance / operations accountable owner / People / workforce accountable owner / 90 days
3	Fraud Detection Capability	Close the material control weakness recorded for "Exception reporting provides defined alerts for unusual transactions or activities and a documented review process".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance / operations accountable owner / 60 days
4	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud and control misuse by people inside the organisation".	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
5	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud threats from external parties relevant to the organisation".	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
6	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance / operations accountable owner / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
7	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Technology / security accountable owner / 60 days
8	Operational Fraud Controls	Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	Finance / operations accountable owner / 60 days
9	Operational Fraud Controls	Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance / operations accountable owner / People / workforce accountable owner / 60 days
10	Operational Fraud Controls	Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance / operations accountable owner / 60 days
11	Operational Fraud Controls	Close the material control weakness recorded for "held assets and physical assets are safeguarded and reconciled by defined people".	Operations and Finance must maintain a complete held assets and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Finance / operations accountable owner / 90 days
12	Fraud Detection Capability	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Risk / compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Governing body / independent oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk / compliance accountable owner / 30 days
13	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The Governing body / independent oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Governing body / independent oversight / 90 days
14	Fraud Incident Response	Close the material control weakness recorded for "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure".	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Finance / operations accountable owner / Legal / investigations accountable owner / 30 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
15	Fraud Incident Response	Close the material control weakness recorded for "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal / investigations accountable owner / Finance / operations accountable owner / 60 days
16	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Relevant external stakeholders have an appropriate way to report suspected fraud or misconduct".	The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	Governing body / independent oversight / CEO / 60 days
17	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "The organisation receives and reviews risk information about high-risk third parties managed on its behalf".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance / operations accountable owner.	Finance / operations accountable owner / 90 days

E2. Definitions and score basis

How the score is calculated

Each applicable assessment response is normalised to a 0–100 control score and weighted within its domain. Domain scores are then combined using the methodology's domain weights to produce the overall readiness score. A control recorded as not applicable is excluded from its scoring denominator rather than treated as a weakness.

The weighted overall score is 43.33/100, which maps numerically to Developing. The final maturity shown in this report is Developing. The next numerical band begins at 60/100; a higher numerical score alone does not override a stricter applicable maturity ceiling.

Maturity scale

MATURITY	SCORE RANGE	INTERPRETATION
Reactive	0–<40	Foundational controls are limited or mainly reactive.
Developing	40–<60	Core control elements exist but are incomplete, inconsistent or not yet connected.
Structured	60–<80	Controls are more consistently defined, owned and operated.
Strategic	80–100	Fraud-risk management is embedded, monitored and continually improved.

Maturity ceilings

Maturity ceilings protect against a strong average masking a material weakness. A hard-gate critical control scored 0 or 1 sets a maximum of Developing; a hard-gate control scored 2 sets a maximum of Structured; three or more critical controls scored 0, 1 or 2 set a maximum of Developing; any core domain below 40 sets a maximum of Developing; and any core domain below 60 sets a maximum of Structured. Where several ceilings apply, the strictest ceiling governs the final maturity.

Reported domain scores

DOMAIN	REPORTED SCORE	MATURITY
Fraud Leadership and Governance	42/100	Developing
Fraud Risk Identification	39/100	Reactive
Operational Fraud Controls	41/100	Developing
Fraud Detection Capability	41/100	Developing
Fraud Incident Response	44/100	Developing
Whistleblowing and Reporting Culture	61/100	Structured
Third-Party and Supply Chain Fraud Risk	47/100	Developing
Digital and Identity Fraud Risk	38/100	Reactive
Fraud Culture and Awareness	57/100	Developing
Continuous Improvement and Fraud Risk Monitoring	41/100	Developing

Risk priority uses the deterministic qualitative likelihood/impact matrix. Risks in the same priority class are not further ranked by their display sequence. Priority and materiality are derived from assessment evidence; neither is an independent risk assessment.